

NOTE DE SECURITE

PsyConnect - Etat actuel, points forts et limites

Objet	Note de synthese pour le chapitre Realisation / Securite.
Perimetre	Analyse fondee sur la configuration et le code actuellement presents dans le depot PsyConnect.

1. Conclusion synthetique

PsyConnect dispose de mecanismes de securite applicative significatifs pour un prototype academique : authentication JWT, chiffrement des mots de passe, gestion des roles et controles d'appartenance aux ressources. **Cependant, l'application ne doit pas etre presentee comme prete pour une mise en production dans le domaine de la sante.** La gestion centralisee des secrets, le chiffrement des donnees sensibles au repos, le deploiement HTTPS et les controles d'exploitation restent a renforcer.

2. Points positifs observes

- Authentication par jetons JWT : les requetes protegees exigent un jeton valide et les services disposent de filtres de securite.
- Mots de passe proteges avec BCrypt : les mots de passe ne sont pas conserves en clair dans la base de donnees.
- Controle d'accès par role : les roles PATIENT, PSYCHOLOGIST et ADMIN permettent de separer les permissions, notamment pour les routes d'administration.
- Controle d'appartenance (ownership) : les services metier verifient que l'utilisateur connecte accede seulement a ses propres rendez-vous, messages, paiements, notifications ou donnees de suivi.
- Separation des responsabilites : le recours a des microservices, un API Gateway et un service de decouverte facilite la structuration des controles et des flux applicatifs.

3. Limites a presenter avec transparence

Point	Constat actuel	Amelioration envisagee
Secret JWT	Une cle par default est visible dans la configuration du projet et dans Docker Compose.	Utiliser des variables d'environnement protegees ou un gestionnaire de secrets ; ne jamais versionner une cle de production.
Donnees sensibles	Aucun chiffrement au repos n'est clairement mis en oeuvre pour les	Chiffrer les champs ou volumes sensibles, limiter les acces BD et

	donnees cliniques, journaux, notes et messages.	definir une politique de sauvegarde.
Transport	Le fonctionnement local est en HTTP ; la terminaison TLS/HTTPS n'est pas decrite pour un deploiement reel.	Placer le Gateway derriere HTTPS avec certificats et ne pas exposer directement les microservices.
Protection contre les abus	La limitation de tentatives de connexion, le verrouillage temporaire et la protection contre le bruteforce ne sont pas identifiees.	Ajouter rate limiting, journalisation des echecs et politique de verrouillage/reinitialisation.
Exploitation	Rotation des secrets, audit de dependances, supervision securite et plan de reponse aux incidents ne sont pas formalises.	Mettre en place des procedures d'exploitation et des controles periodiques avant tout deploiement public.

4. Positionnement recommande dans le memoire

Formulation suggeree : « La solution PsyConnect integre une securite applicative fondee sur l'authentification JWT, le hachage BCrypt des mots de passe, la gestion des roles et le controle d'appartenance des ressources. Ces mecanismes protegent les principaux acces fonctionnels du prototype. Pour une mise en production dans le secteur de la sante, ils devront etre completes par le chiffrement des donnees au repos, une gestion centralisee des secrets, le deploiement HTTPS, des mecanismes de prevention contre les abus et une politique d'audit. »

5. Perimetre de la demonstration

- Pour la soutenance, demontrer la connexion, la separation des roles et au moins deux refus d'accès : par exemple un patient tentant de lire une ressource d'un autre patient, puis un utilisateur non administrateur tentant d'accéder a une route admin.
- Ne pas revendiquer une conformite complete de production ou de sante. Presenter les limites comme des perspectives de securisation et de deploiement futur.
- Conserver les paiements en mode simule est coherent avec un prototype local : aucune donnee bancaire ni aucun transfert reel n'est traite.